

Admin Able to Create User Without Setting a Password in mlflow/mlflow

✓ Valid

Reported on Nov 20th 2024

Description

The application allows an admin to create a new user account without assigning a password. This could lead to security vulnerabilities, or the system might inadvertently create an account with a default or blank password, making it susceptible to unauthorized access.

Proof of Concept

- Log in as an admin.
- Navigate to the signup page
- Fill in the required fields (e.g., username) but leave the password field blank.
- Submit the form to create the user.

Impact

- Security Risk: Accounts without passwords may be vulnerable to unauthorized access.
- Compliance Concerns: Violates best practices for secure user account management

 We are processing your report and will contact the **mlflow** team within 24 hours. a year ago

 A **GitHub Issue** asking the maintainers to create a `SECURITY.md` exists a year ago



 **huntr-helper** modified the Severity from Medium (4.3) to Low (3.8) a year ago



Harutaka Kawamura commented a year ago

Maintainer

Thanks for the report. Filed <https://github.com/mlflow/mlflow/pull/13854>.

 flow



A **mlflow/mlflow** maintainer has acknowledged this report a year ago

 The scheduled publication date was automatically extended from 18th Feb 2025 to 25th Feb 2025 due to the maintainers acknowledgement of the report a year ago



Krishna commented a year ago

Researcher

Ok Let me know if there is any update .



Krishna commented a year ago

Researcher

is it fixed now ?



Harutaka Kawamura commented a year ago

Maintainer

yes



Krishna commented a year ago

Researcher

UPDATE ON THE REPORT ?



Krishna commented a year ago

Researcher

Kindly Update the report ?



Krishna commented a year ago

Researcher

Hello please update on the report



Krishna commented a year ago

Researcher

UPDATE ON THE REPORT ?



Krishna commented a year ago

Researcher

Hello please give some update on the report

✉ We have notified the **mlflow/mlflow** maintainers about this report in their weekly follow-up a year ago

[Sign in](#) to join this conversation

Vulnerability Type

CWE-521: Weak Password Requirements

Severity

Low (3.8)

Attack vector	Network
Attack complexity	Low
Privileges required	High
User interaction	None
Scope	Unchanged
Confidentiality	Low
Integrity	Low
Availability	None

[Open in visual CVSS calculator](#)

Registry

Pypi

Affected Version

2.18

Visibility

Public

Status

Fixed

Disclosure Bounty

\$20

Fix Bounty

\$5

Found by



Krishna

@krishnast545

LIGHTWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.

